

Assignment 1 – Simulating a Security Audit based on ISO27001:2022

Working as a team of **four**, you will act as external security auditors for the assigned company. Your team has been hired as external security auditors to conduct a preliminary security audit and provide a report on compliance with ISO 27001.

Your primary objective is to evaluate the organization's current security framework, identify gaps in compliance with ISO 27001 requirements, and produce a report presenting the findings. The audit will focus on domains identified for each scenario.

1 Assignment definition

This assignment is divided into 2 major parts, each demanding a deliverable to be submitted.

1.1 Milestone 1: Planning the Audit

1. Understand ISO27001 Requirements
 - Research and summarize the key requirements of ISO27001, focusing on the domains identified in the assigned scenario and the presented Statement of Applicability (SoA).
2. Define Audit Objectives
 - Outline specific goals for the audit.
3. Prepare an Audit Plan
 - Detail the scope, methods, and timeline for your audit activities.

Deliverable: A complete audit plan should be submitted in *Inforestudante* by **March 15th, 23:59** (10%).

1.2 Milestone 2: Conducting the Audit and Reporting Findings

1. Simulate the audit execution and record all relevant evidence.
2. Document Audit Findings
 - Prepare a detailed report highlighting the identified gaps and the corresponding ISO 27001:2022 controls affected.

Deliverable: A detailed report containing all Milestone 2 information should be submitted to *Inforestudante* by **April 19th, 23:59** (30%).

At the end of the work, each team will give a 10-minute presentation to the assigned leadership team summarizing the audit's key outcomes. This presentation will be made in the classes on **April 20th**.

2 Assessment criteria

2.1 General criteria

- **Depth of Analysis:** Demonstrating a thorough understanding of ISO27001 controls and their application.
- **Professionalism:** Clarity, structure, and professionalism of the report and presentation.
- **Team Collaboration:** Evidence of collaborative effort in conducting the audit and preparing deliverables.

2.2 Milestone 1 Criteria

- The plan covers all the necessary steps for executing a Security Audit under ISO27001, given the assigned scenario.
- The audit scope is adapted to the assigned scenario.

2.3 Milestone 2 Criteria

- All audit evidence and findings were correctly documented.
- Compliance gaps were identified and characterized using ISO 27001 controls.
- A clear, assertive report was produced

2.4 Final Presentation Criteria

- The presentation is clear and focused on communicating the audit results to a leadership team.
- The presentation contains correct, objective information.
- All team members participate in the presentation.
- The team can engage with the audience.
- The team demonstrates knowledge of the topic and can answer questions about it.

3 Scenario A – SecureCart Inc.

3.1 Company Overview

SecureCart Inc. is a mid-sized e-commerce company that sells consumer electronics, fashion items, and home appliances through its online platform. Over the past five years, the company has experienced rapid growth, expanding its customer base to over 1 million active users. SecureCart Inc. processes a high volume of sensitive customer information daily, including personal details such as names, addresses, and payment data (e.g., credit card information). Additionally, the company processes payments through third-party payment gateways and cloud-based solutions.

The company operates through a centralized IT infrastructure supported by cloud-based services and a custom-developed e-commerce platform. Its core departments include IT, Operations, Marketing, Customer Support, and Finance, each of which relies heavily on digital systems to execute daily tasks. IT manages the platform's maintenance, software updates, and security configurations. Operations oversees order fulfillment and inventory tracking, while Customer Support handles thousands of queries daily through online chat and email systems. Marketing runs promotional campaigns using customer data for personalization, and Finance manages payment processing and financial reporting.

3.1.1 Security Challenges

Despite its success, SecureCart Inc. has faced increasing challenges in managing cybersecurity risks as its infrastructure grows and its workforce expands. Specific concerns include:

- **Data Breaches:** The company has faced multiple phishing attempts and malware attacks targeting customer and payment data.
- **Access Control:** Employees sometimes retain access to sensitive systems even after changing roles or leaving the organization, increasing the risk of unauthorized access.
- **Incident Response:** While the company has an incident response plan, it has not been tested or updated in the last year, raising concerns about its effectiveness.
- **Third-Party Risks:** Reliance on third-party payment gateways and cloud providers introduces potential vulnerabilities if these partners fail to maintain robust security measures.

A recent internal review highlighted vulnerabilities in these areas, leading the management team to prioritize information security. To address these concerns and bolster customer trust, the company has committed to achieving ISO27001 certification. This certification is seen as a strategic step toward ensuring robust information security and maintaining compliance with international standards.

In the next sections, we present the policies and practices SecureCart already has in place that are relevant to the assignment.

NOTE: You should consider only the information presented here to identify security gaps and map to ISO27001:2022 controls.

3.2 Information Security Governance

3.2.1 Information Security Policy (High-Level)

- States a commitment to confidentiality, integrity, and availability.
- Security responsibility is assigned to the Head of IT.
- Annual policy review planned.

Current Practices

- Security awareness training exists, but it is optional.
- Policies are distributed via the internal wiki.
- No systematic confirmation that employees read or accept policies.

3.2.2 2.2 User Identification & Access Control Policy

The company defines the following principles:

- Unique usernames for each employee.
- Role-based access control (RBAC).
- Passwords change every 90 days.
- Access to production systems is limited to the IT team.

Current Practices

- Shared admin accounts still exist for legacy systems.
- Developers frequently access production databases for troubleshooting.
- MFA is enabled only for VPN access, not internal cloud dashboards.
- The HR onboarding/offboarding process relies on manual email requests.

3.2.3 Privacy & Data Protection Policy

SecureCart states it complies with GDPR-like principles:

- Collection limitation.
- Data minimization.
- Purpose limitation.
- Right to erasure.

Current Practices

- Marketing exports customer datasets locally for analysis.
- Customer support tickets sometimes include full payment information.
- Data retention rules exist, but are inconsistently applied.
- No structured process to classify personal vs. sensitive information.

3.2.4 Asset Management Policy

The organization defines information assets as:

- Servers
- Databases
- Cloud services
- Laptops
- Source code repositories

Asset owners should:

- Maintain inventory records.
- Ensure patching.
- Define classification levels (Public/Internal/Confidential).

Current Practices

- Asset inventory is maintained in spreadsheets.
- Cloud assets are created dynamically without inventory updates.
- No data classification labels applied in practice.
- Bring-Your-Own-Device (BYOD) allowed for some remote developers without formal approval.

3.3 Operational Security Context

3.3.1 Security Monitoring

- Logs are collected in a centralized SIEM.
- Alerting rules exist, but are not regularly tuned.
- No documented log retention policy.

3.3.2 Incident Management

- Incident Response Plan created 18 months ago.
- No tabletop exercises performed.
- Roles in incident response are unclear.
- Forensics capability outsourced but not contractually defined.

3.4 Third-Party and Supply Chain Context

SecureCart relies on:

- Payment gateway providers.
- Cloud hosting provider.
- External marketing analytics tool.
- Offshore development contractor.

Current situation:

- Contracts focus mainly on SLA availability.
- Security requirements are inconsistently included.
- No formal supplier risk assessment process.
- Vendor security audits are ad hoc.